Data Loss Prevention (DLP) Policies for external devices

Introduction to Data Loss Prevention

Data Loss Prevention (DLP) is a set of tools and processes designed to detect and prevent the unauthorized use and transmission of sensitive information. DLP is crucial in today's digital landscape for several reasons:

Protection of Sensitive Data: DLP helps organizations safeguard their most valuable asset – information.

Compliance: Many industries are subject to regulations that require the protection of specific types of data.

Reputation Management: Data breaches can severely damage an organization's reputation and customer trust.

Insider Threat Mitigation: DLP can help prevent both accidental and intentional data leaks by employees.

Data Classification

Effective DLP starts with knowing what sensitive data you have and where it's located. Organizations have to properly identify and classify all of its sensitive data, which is a crucial first step in DLP.

Example:

Public Data
- Avoid posting confidential information on public websites.
- Avoid sharing sensitive data on social media platforms.

Internal Data
- Don't leave sensitive documents unattended.
- Use proper disposal of printed materials.

Sensitive Data
- Avoid uploading sensitive data to unsecured cloud services.
- Avoid sharing files with overly broad permissions (Access rights that are too generous).

*Tools for implementing data classification:

Microsoft Information Protection
Titus Classification Suite
Boldon James Classifier
Varonis Data Classification Engine
BigID Data Intelligence

Access and Control

Restricted Access
Employees will have access only to the documents and folders needed for their daily tasks. General access to sensitive folders will be avoided.

Permission Review
Access permissions to sensitive documents, files and folders will be reviewed quarterly to ensure that only active and authorized personnel retain access.

Temporary Access
When temporary access to sensitive documents is required, it will be granted through formal authorization and removed once the project or task is completed.

Limited Editing Permissions
Only direct supervisors will have editing permissions.
Other employees may have read-only access if necessary for their roles.

Monitoring and Auditing

Monitoring and auditing policy will be implemented to detect unauthorized access and misuse.

Protecting Data: at rest, in motion and in use.

Data at Rest: Tools for encrypting data at rest:
BitLocker (Windows)
FileVault (macOS)
VeraCrypt (cross-platform)
LUKS (Linux)
AWS Key Management Service

Data in Motion: Strategies for securing data in motion:
SSL/TLS
IPsec VPN
SFTP
HTTPS
Network Segmentation

Data in Use: Strategies for securing data in use:
Screen Capture Prevention
Copy-Paste Restrictions
Watermarking
Application Sandboxing
Memory Encryption

Wazuh as an EDR (Endpoint Detection and Response)

Wazuh's file integrity monitoring (FIM) feature tracks changes to critical files and directories on monitored systems. It can detect unauthorized modifications, additions, or deletions of files, helping to identify potential security breaches or malicious activities. FIM also aids in compliance by ensuring that important system files remain unaltered and secure.

Wazuh as a SIEM (Security Information and Event Management)

Real-time alerting and monitoring
The platform provides instant notifications for potential security incidents, allowing rapid response to threats. Its real-time monitoring capabilities offer continuous visibility into system activities, helping to maintain a proactive security posture.

Compliance reporting and auditing
Wazuh simplifies compliance management by automating the generation of reports for various regulatory standards. It also facilitates thorough auditing processes, tracking system changes and user activities to ensure adherence to security policies and regulations.

An NDR can improve an organization's security and detect unauthorized access and misuse

Network Detection and Response (NDR) is a cybersecurity solution that ingests network traffic and uses machine learning to detect malicious activity and understand security risks and exposure. It combines detection of known attack behaviors with the ability to understand what is normal for a given organization, signaling unusual changes that may indicate an attack.

*NDR Tool:

Darktrace (AI-based anomaly detection, self-learning models, autonomous response (via Antigena)).

Leak Prevention

Encrypt all sensitive data, and use DLP tools to monitor, control, and enforce how data is accessed, shared, and stored—across devices, cloud apps, and networks.

Technologies such as encryption and DLP tools:

BitLocker (Windows)
FileVault (macOS)
VeraCrypt (cross-platform)

SSL/TLS
IPsec VPN
SFTP

Screen Capture Prevention
Copy-Paste Restrictions
Watermarking

Education and Awareness

Training staff on security policies and associated risks is essential to maintaining an organization's cybersecurity posture.

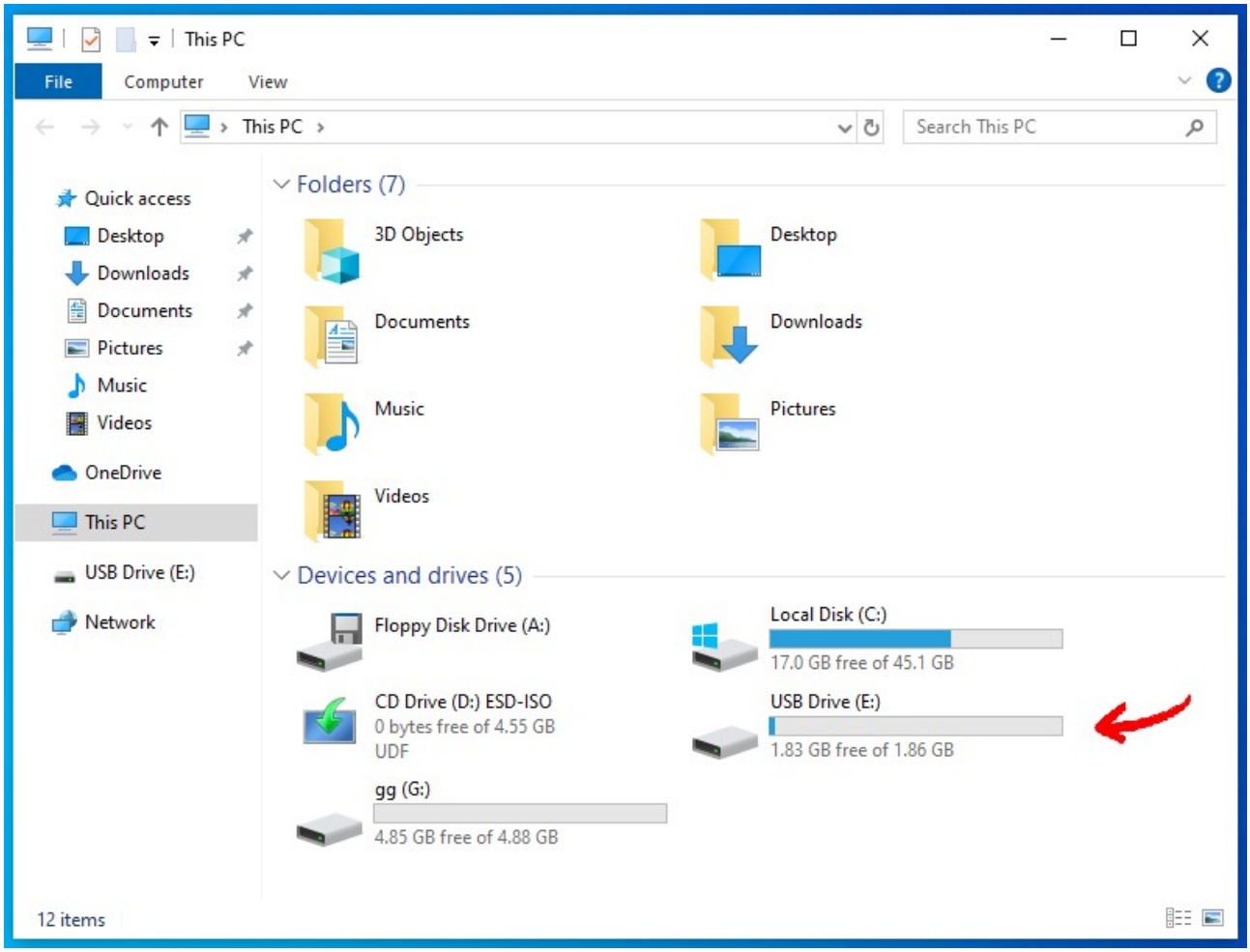
Example:

Live sessions led by a cybersecurity expert.
Direct interaction and Q&A.

Simulated phishing emails sent to staff to test awareness and response.
Practical and realistic experience.

Staff are required to read and acknowledge key security policies of their organization.
This way we ensure employees are aware of specific responsibilities.

Implementation of USB Device Restriction Policies



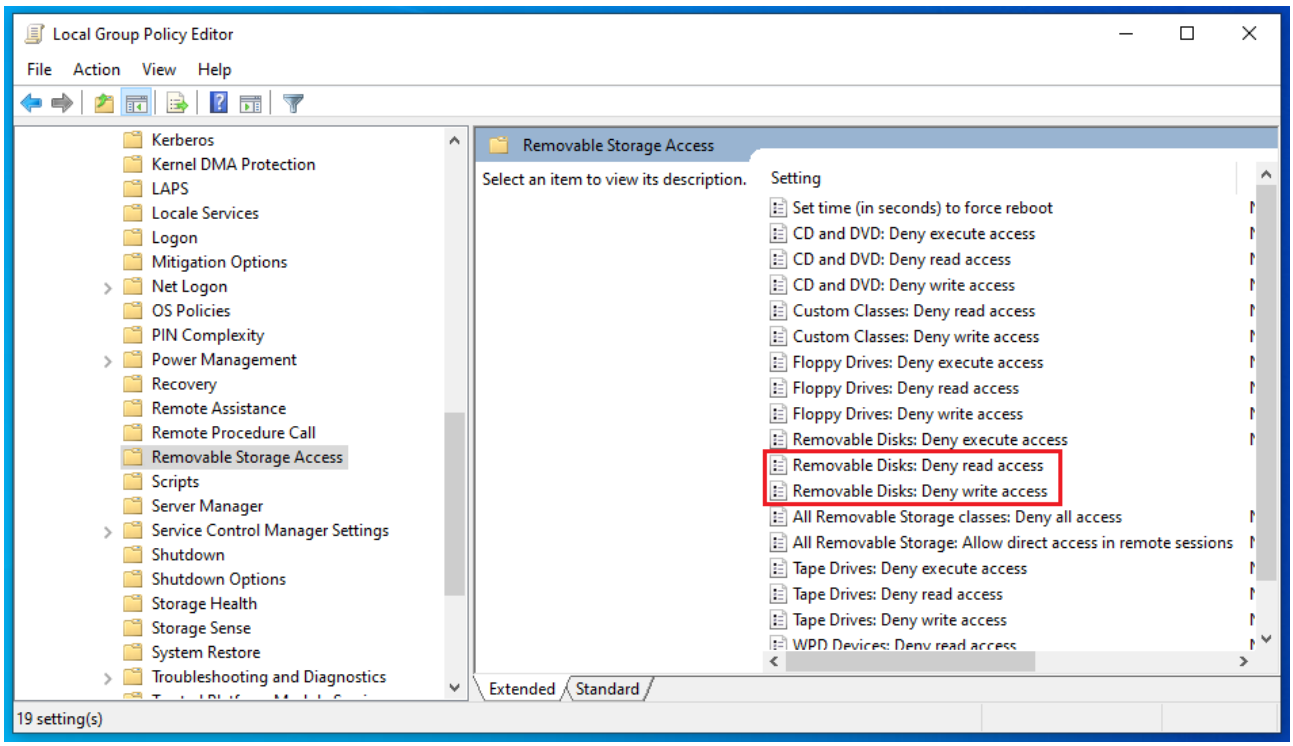
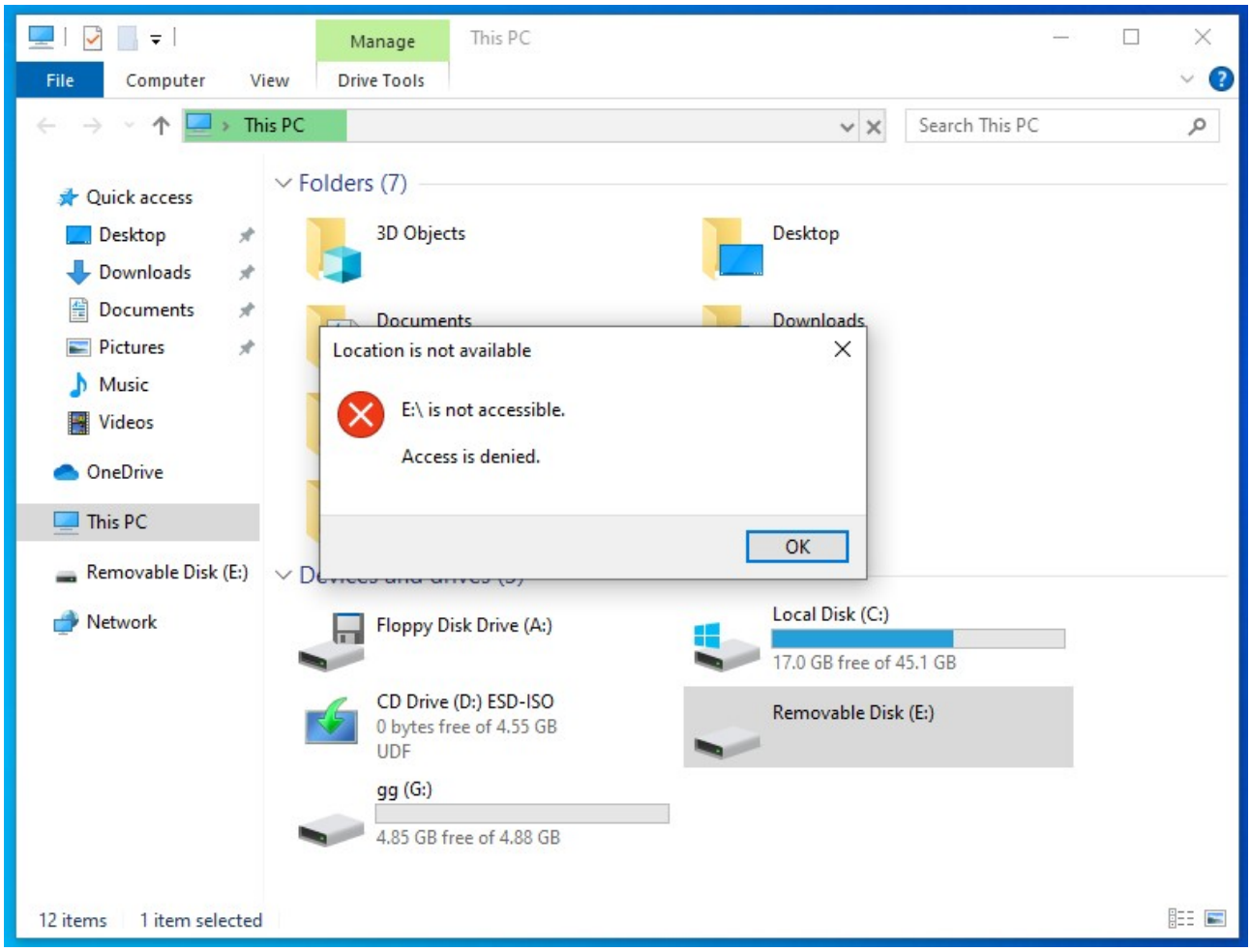
USB Device Restriction in Windows

Open the Group Policy Editor. Press Win + R, type gpedit.msc, and press Enter to open the Group Policy Editor.

Navigate to Removable Storage Policies. Go to Computer Configuration > Administrative Templates > System > Removable Storage Access.

Configure the Policy to Deny Access to USB Devices. Enable the following policies:

Removable Disks: Deny read access.
Removable Disks: Deny write access.



Validation and Testing of USB Restriction